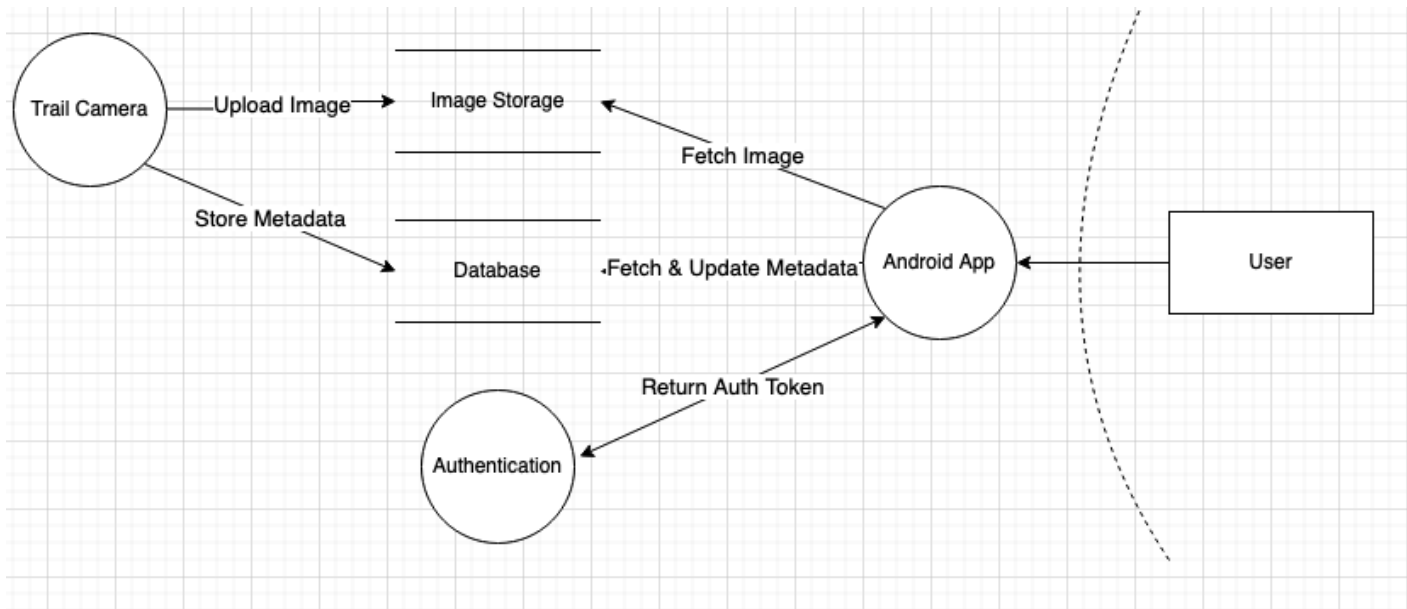


ASTC Threat Assessment using the STRIDE Framework

1. Identify Assets

Asset	Description
Trail Cameras	Captures images, processes data locally, and stores/sends data.
AI Model	Classifies images and identifies animals.
Database (Labeled Dataset)	Stores labeled images for model training and tracking.
Storage (Local & Cloud)	Stores raw and classified images (Local SD card, AWS S3, or Firebase Storage).
Network Communication	Transfers data from cameras to the database via Wi-Fi or LTE.
Android Mobile App (User Interface)	Allows users to access, review, and manage images from their mobile device.
Authentication (Firebase)	Users authenticate using Firebase Authentication.
Logging & Monitoring System	Tracks system activity and logs errors or security events.

2. Data Flow Design



3. DFD STRIDE

Flow	Threats (STRIDE)	Mitigation Strategies
Camera → Storage	Spoofing, Tampering, Information Disclosure	Use mutual TLS (mTLS), validate upload source, encrypt files (AES-256).
Camera → DB	Tampering, Repudiation	Store integrity hashes, restrict DB writes to authenticated devices.
Mobile App → Firebase Auth	Spoofing, Elevation of Privilege	Enforce MFA, use OAuth tokens.
Mobile App → DB	Information Disclosure	Restrict database rules with user-based permissions.
Mobile App → Storage	Denial of Service	Rate-limit API requests, set storage quotas.

4. COMPONENT STRIDE

(A) Android Mobile App

Threat	Description	Mitigation Strategies
S - Spoofing	An attacker installs a rogue app impersonating the official Smart Trail Camera app.	Use Google Play signing, enforce app integrity verification, allow installation only from trusted sources.
T - Tampering	Malicious modification of the app code (e.g., reverse engineering, injecting malware).	Code obfuscation, anti-tampering mechanisms, integrity checks (e.g., Google Play Protect, SafetyNet).
R - Repudiation	Users deny performing actions (e.g., modifying labeled dataset).	Firebase Firestore rules, timestamped audit logs.
I - Information Disclosure	Data leakage via insecure local storage, clipboard usage, or log exposure.	Encrypt local storage, disable logging in production, restrict clipboard access.
D - Denial of Service	Excessive API calls or UI crashes render the app unusable.	Implement API rate limiting, crash recovery, and error handling.
E - Elevation of Privilege	Malicious app exploits permission misconfigurations to gain access to camera data.	Use least privilege permissions, enforce Android runtime permissions, validate intent calls.

(B) Trail Cameras

Threat	Description	Mitigation Strategies
S - Spoofing	An attacker installs a rogue camera impersonating an authorized one.	Secure device authentication, unique cryptographic identity per camera.
T - Tampering	Physical access allows attackers to modify firmware or data.	Secure boot, encrypted firmware updates, tamper-resistant hardware.
R - Repudiation	An attacker manipulates logs to remove traces of their actions.	Secure logging with cryptographic integrity checks.
I - Information Disclosure	Unauthorized access to stored images and data.	Local data encryption (AES-256), secure transmission (TLS).
D - Denial of Service	Overloading camera resources via excessive requests.	Rate limiting, watchdog timers, reboot mechanisms.
E - Elevation of Privilege	Malicious firmware update gains root access.	Digitally signed firmware updates, secure authentication for maintenance.

(C) AI Model

Threat	Description	Mitigation Strategies
S - Spoofing	Injecting fake images to manipulate AI results.	Model integrity checks, adversarial training, digital signatures for images.
T - Tampering	Modifying training data to bias results.	Secure dataset storage, model validation on deployment.
R - Repudiation	An attacker denies responsibility for malicious model behavior.	Audit logs, version-controlled models.
I - Information Disclosure	Extracting AI model details for adversarial attacks.	Model obfuscation, access control for model files.
D - Denial of Service	Feeding excessive images to exhaust AI processing.	Rate limiting, anomaly detection in input data.
E - Elevation of Privilege	Malicious AI model update deployed.	Signed model deployments, restricted access to AI training pipeline.

(D) Database (Labeled Dataset)

Threat	Description	Mitigation Strategies
S - Spoofing	Unauthorized users gain access and modify dataset labels.	Enforce Firebase Firestore security rules, use Firebase Authentication.
T - Tampering	Modifying stored labels or metadata.	Database integrity checks, version control, logging changes.
R - Repudiation	Users deny modifying dataset records.	Firestore audit logs, timestamped record modifications.
I - Information Disclosure	Unauthorized users access labeled datasets.	Restrict access using Firebase rules, encrypt data.
D - Denial of Service	Large dataset requests slow down database performance.	Limit read/write operations, set Firestore rate limits.
E - Elevation of Privilege	Unauthorized user modifies dataset permissions.	RBAC in Firebase Authentication, Firebase IAM policies.

(E) Storage (Local & Firebase Cloud)

Threat	Description	Mitigation Strategies
S - Spoofing	Fake storage locations trick the system into saving sensitive data.	Validate storage endpoints, encryption in transit.
T - Tampering	Modifying stored images or metadata.	Write-protection, integrity hashing (SHA-256) for stored images.
R - Repudiation	Deleting or altering logs of stored files.	Immutable storage, audit logs, access controls.
I - Information Disclosure	Leaking sensitive images due to misconfigured access.	Secure Firebase Storage rules, access control lists (ACLs).
D - Denial of Service	Overloading storage with excessive uploads.	Storage quotas, rate limiting, automatic archiving.
E - Elevation of Privilege	Unauthorized modification of storage settings.	Role-based access control (RBAC), logging access attempts.

(F) Firebase Authentication

Threat	Description	Mitigation Strategies
S - Spoofing	An attacker logs in as another user.	Enforce MFA, use reCAPTCHA for bot protection.
T - Tampering	Modifying Firebase authentication tokens.	Use token expiration, validate tokens server-side.
R - Repudiation	A user denies logging into the system.	Store authentication logs, track IP/device info.
I - Information Disclosure	Exposing user authentication data.	Mask user data in logs, limit API exposure.
D - Denial of Service	Brute-force attack on login endpoints.	Rate limiting, account lockout after failed attempts.
E - Elevation of Privilege	Normal users escalate to admin access.	Use Firebase IAM roles, strict permissions enforcement.

5. Prioritization & Risk Mitigation

Threat Type	Risk Level	Priority
Spoofing	High	Immediate
Tampering	High	Immediate
Repudiation	Medium	Moderate
Information Disclosure	High	Immediate
Denial of Service	Medium	Moderate
Elevation of Privilege	High	Immediate